

Audit légal

Overdrive

Aventix
Epitech Paris
10 février 2026

Sommaire

OverDrive – Audit légal

1- Droits d'exploitation des compétitions sportives

- 1- Cadre juridique (France / Europe)
- 2- Risques pour OverDrive
- 3- Cas des données open source
- 4- Mesures de conformité recommandées

2- Protection des données personnelles (RGPD – email via OAuth)

- 1- Cadre juridique
- 2- Risques pour OverDrive
- 3- Mesures de conformité recommandées

3- Responsabilité civile et obligation d'information (VR)

- 1- Cadre juridique
- 2- Risques potentiels
- 3- Mesures de conformité recommandées

4-Conclusion

Introduction

Cet audit légal a pour objectif d'identifier les principaux risques juridiques liés au développement et à l'exploitation d'OverDrive. Le projet se situe à l'intersection de plusieurs domaines sensibles :

- exploitation de données issues de compétitions sportives,
- diffusion et traitement de données en temps réel,
- gestion de comptes utilisateurs,
- usage de la réalité virtuelle (VR) et réalité augmentée (AR).

Le positionnement premium d'OverDrive implique également un niveau d'exigence élevé en matière de conformité. Cet audit met donc en évidence les points critiques pouvant bloquer le projet et propose des adaptations simples et réalistes pour réduire les risques dès la V1.

1- Droits d'exploitation des compétitions sportives

1- Cadre juridique (France et Europe)

Le sport automobile, en particulier les compétitions organisées par des entités comme la FIA, Formula 1, WEC ou FE, est un secteur fortement encadré juridiquement.

En France et en Europe, plusieurs protections s'appliquent :

- Les organisateurs disposent d'un droit exclusif d'exploitation commerciale de leurs compétitions.
- Les **données officielles en temps réel** (live timing, classements, informations pilotes) peuvent être considérées comme protégées, notamment lorsqu'elles sont issues d'un système propriétaire.
- Les **flux vidéo** sont protégés par le **droit d'auteur**.
- Les bases de données liées à ces compétitions peuvent être protégées par le **droit sui generis des bases de données**, notamment en droit français (article L341-1 du Code de la Propriété Intellectuelle).

Ces protections signifient qu'un produit exploitant des données sportives officielles sans autorisation peut être exposé à un risque juridique important.

2- Risques critiques pour OverDrive

Dans le cadre d'OverDrive, plusieurs risques peuvent apparaître si l'application consomme ou redistribue des données officielles sans droits clairs.

Les actions juridiques possibles incluent :

- **Action en concurrence déloyale** : si OverDrive est perçu comme tirant profit d'un contenu exploité commercialement par un acteur officiel.
- **Action pour parasitisme économique** : si OverDrive exploite l'investissement d'un organisateur sans autorisation, même sans reproduction directe.
- **Action pour extraction illicite de base de données** : si OverDrive extrait une partie substantielle ou répétée d'une base protégée.
- **Mise en demeure par les ayants droit** : pouvant entraîner un blocage rapide du projet ou une obligation de retrait.

Ce point représente le risque légal le plus critique, car il peut empêcher OverDrive d'être distribué ou commercialisé.

3- Cas des données open source

OverDrive peut réduire fortement ce risque si les données utilisées proviennent de sources réellement open source ou publiques.

Cependant, plusieurs vérifications sont nécessaires :

- confirmer que les données sont effectivement libres et réutilisables,
- vérifier la licence (MIT, Apache, CC-BY, ODbL, etc.),
- respecter les obligations de citation ou de redistribution.

Un point important est que certaines sources peuvent être "publiques" dans leur accès mais non libres juridiquement : l'audit doit donc distinguer l'accès technique de la liberté d'exploitation.

4- Adaptations juridiques recommandées

Une adaptation simple et très efficace consiste à mettre en place une documentation claire des sources de données.

Recommandations :

- créer un fichier `DATA_SOURCES.md` dans le repository,
- lister systématiquement :
 - la source,
 - la licence,
 - les conditions de réutilisation,

- les obligations de mention,
- afficher les mentions nécessaires dans :
 - l'interface (si requis),
 - ou la documentation (README / page légale).

Cette démarche permet de renforcer la transparence et de limiter les risques de contestation.

2- Protection des données personnelles (RGPD - email via OAuth)

1- Cadre juridique

OverDrive implique la création de comptes utilisateurs et donc le traitement de données personnelles.

En France et en Europe, ce traitement est encadré par :

- le Règlement Général sur la Protection des Données (RGPD — UE 2016/679),
- la Loi Informatique et Libertés modifiée.

Deux articles du RGPD sont particulièrement importants :

- **Article 5** : principe de minimisation des données (ne collecter que ce qui est nécessaire).
- **Article 6** : base légale du traitement (justification du traitement des données).

2- Risques pour OverDrive

Les principaux risques RGPD pour OverDrive sont :

- collecter une donnée personnelle sans base légale claire,
- ne pas informer correctement l'utilisateur (transparence),
- conserver les données trop longtemps ou sans politique claire,
- mauvaise configuration OAuth, entraînant une collecte excessive (ex : profil complet, contacts, informations non nécessaires).

Même si OverDrive ne collecte que peu de données, une non-conformité sur l'information utilisateur ou la configuration OAuth peut suffire à rendre le traitement problématique.

3- Approche recommandée : minimisation stricte

La stratégie la plus cohérente pour OverDrive est une approche “privacy by design”, très simple :

- collecter uniquement l’email,
- utiliser l’email uniquement pour l’authentification,
- ne stocker aucune donnée externe supplémentaire.

Cette approche est parfaitement alignée avec :

- le positionnement premium (confiance),
- la simplicité technique,
- les obligations RGPD.

4- Adaptations juridiques simples

Deux mesures simples permettent de réduire fortement le risque :

1. Limiter le scope OAuth au strict minimum, idéalement :
 - email uniquement.
2. Ajouter une Privacy Policy courte, claire et accessible, mentionnant explicitement :
 - “L’email est utilisé uniquement à des fins d’authentification.”
 - les règles de conservation,
 - les droits utilisateur (accès, suppression).

Cette politique peut être intégrée dans le web dashboard et accessible depuis l’application mobile.

3. Responsabilité civile et obligation d’information (VR)

1- Cadre juridique

Contrairement à d’autres domaines technologiques, la réalité virtuelle ne dispose pas aujourd’hui d’une loi spécifique en France.

La responsabilité repose donc sur le droit commun, notamment :

- **Article 1240 du Code civil** : responsabilité pour faute.

- Article 1112-1 du Code civil : obligation d'information.
- Article L421-3 du Code de la consommation : principe général de sécurité.

Cela signifie que si un utilisateur subit un dommage lié à l'usage VR, la question centrale devient :

- le produit a-t-il correctement informé l'utilisateur des risques connus ?

2- Risques potentiels

Les risques VR sont bien identifiés dans la littérature et dans les standards d'usage. Les principaux sont :

- inconfort visuel,
- fatigue,
- nausées,
- désorientation.

En cas de dommage, l'absence d'avertissement clair pourrait être considérée comme une faute, surtout si le risque est connu et prévisible.

3- Adaptations juridiques recommandées

Une adaptation simple consiste à intégrer un message d'avertissement au lancement de l'application VR.

Exemple recommandé :

“L'utilisation prolongée de dispositifs VR peut entraîner inconfort ou fatigue. Il est recommandé de faire des pauses régulières.”

Deux compléments importants sont également recommandés :

- ne jamais garantir une expérience “sans risque”,
- rappeler que l'utilisateur reste responsable de son environnement physique (espace libre, obstacles, sécurité).

Ces mesures sont légères, peu coûteuses, et permettent de réduire significativement le risque juridique.

Conclusion

L'audit légal met en évidence trois axes majeurs de vigilance pour OverDrive.

1. Droits d'exploitation des compétitions sportives

C'est le risque le plus critique, car il peut bloquer totalement le projet si les données exploitées ne sont pas autorisées. La solution passe par une stratégie claire : utiliser des sources open source ou sous licence, et documenter systématiquement les sources.

2. Protection des données personnelles (RGPD)

OverDrive peut rester très conforme grâce à une collecte minimale (email uniquement) et une configuration OAuth stricte. Une Privacy Policy courte et claire permet de sécuriser ce point dès la V1.

3. Responsabilité civile liée à l'usage VR

Même sans loi spécifique, le droit commun impose une obligation d'information. Un avertissement simple au lancement et une communication claire sur les risques VR réduisent fortement l'exposition juridique.

En appliquant ces recommandations dès la première version, OverDrive peut construire une base solide de conformité, cohérente avec son positionnement premium et sa crédibilité long terme.